

Mapeo de Preguntas a Requisitos Normativos

Nº Pregunta	Tema resumido	NIST SP 800-55 / NIST CSF	ENS / NIS2 / RGPD / Otros
2.1	Programa formal de medición	SP 800-55 Vol. 2: desarrollo del programa de medición	ENS: principios de mejora continua; NIS2: gestión de riesgos
2.2	Objetivos de negocio ligados a métricas	SP 800-55 Vol. 1: identificación de objetivos de medición	NIS2: enfoque basado en riesgos; ERM corporativo
2.3	Inventario de métricas	SP 800-55 Vol. 1: catálogo de medidas	ENS: documentación de medidas de seguridad
2.4	Responsabilidad sobre métricas	SP 800-55 Vol. 2: gobernanza del programa	ENS: responsabilidad de la dirección; NIS2: órgano de gestión
2.5	Revisión periódica	SP 800-55 Vol. 2: ciclo de vida de la medición	ENS: revisión continua; NIS2: revisión periódica de medidas
2.6	Calidad de datos	SP 800-55 Vol. 2: calidad y gestión de datos	Buenas prácticas de gobierno del dato
3.1	Tipos de métricas	SP 800-55 Vol. 1: eficacia, eficiencia, impacto, cumplimiento	ENS: medidas y niveles; NIS2: medidas técnicas y organizativas
3.2	Naturaleza cuantitativa/cualitativa	SP 800-55 Vol. 1: medidas cuantitativas y cualitativas	Buenas prácticas de medición
3.3	Influencia en presupuesto	SP 800-55 Vol. 2: uso de métricas en decisiones	Principios de gestión de riesgos y recursos
3.4	Relación con ERM	SP 800-55: integración con gestión de riesgos	NIS2: integración con gestión de riesgos corporativos
4.1	Registro y clasificación de incidentes	NIST CSF: DE.AE, RS.AN	ENS: gestión de incidentes; NIS2: notificación de incidentes
4.2	Herramientas de registro de incidentes	NIST CSF: DE.AE-2, RS.MI	ENS: registro de eventos e incidentes
4.3	Indicadores de incidentes	SP 800-55 Vol. 1: métricas de incidentes	NIS2: reporting; ENS: gestión de incidentes
4.4	Segmentación por tipo de amenaza	NIST CSF: ID.RA	ENS: análisis de riesgos
4.5	Segmentación por unidades o sistemas	NIST CSF: ID.AM, ID.RA	ENS: categorización de sistemas
4.6	Intercambio con CSIRTs/CERTs	NIST CSF: RS.CO	NIS2: cooperación y notificación a CSIRT

5.1	Arquitectura Zero Trust	NIST SP 800-207; NIST CSF: PR.AC, PR.PT	NIS2: medidas técnicas robustas
5.2	MFA y control de acceso	NIST CSF: PR.AC; SP 800-53: AC-*	NIS2: control de acceso fuerte; ENS: control de acceso
5.3	Segmentación de red	NIST CSF: PR.AC-5, PR.PT	ENS: protección de comunicaciones; NIS2: seguridad de redes
5.4	Gestión de vulnerabilidades	NIST CSF: ID.RA, PR.IP-12	ENS: gestión de vulnerabilidades
5.5	Eficacia de antimalware/EDR/XDR	NIST CSF: PR.IP, DE.CM	NIS2: medidas técnicas; ENS: protección frente a código malicioso
6.1	Inventario de requisitos normativos	SP 800-55: contexto organizativo	ENS, NIS2, RGPD: obligaciones de cumplimiento
6.2	Niveles de cumplimiento ENS/NIS2	SP 800-55: métricas de cumplimiento	ENS: niveles de seguridad; NIS2: supervisión y reporting
6.3	Objetivos de mejora de cumplimiento	SP 800-55 Vol. 2: objetivos de medición	ENS/NIS2: mejora continua
6.4	Auditorías de ciberseguridad	NIST CSF: ID.GV	ENS: auditoría periódica; NIS2: supervisión
6.5	Coste de cumplimiento	SP 800-55: métricas de eficiencia	Gestión financiera; impacto regulatorio
7.1	Plan de formación	NIST CSF: PR.AT	ENS: formación en seguridad
7.2	Métricas de formación y concienciación	SP 800-55: métricas de concienciación	ENS/NIS2: medidas organizativas
7.3	Indicador de madurez	SP 800-55: madurez y capacidad	Modelos de madurez (CMMI, ISO 27001, NIST CSF)
7.4	Métricas ligadas a incentivos	SP 800-55: uso de métricas en la gestión	Buenas prácticas de gobierno corporativo
7.5	Clima cultural	SP 800-55: aspectos cualitativos de la seguridad	Cultura de seguridad (ENS, NIS2)
8.1	Impacto económico de incidentes	SP 800-55: métricas de impacto	Gestión de riesgos; seguros de ciberriesgo
8.2	Costes/pérdidas evitadas	SP 800-55: eficiencia y eficacia	Justificación de inversiones
8.3	Modelos actuariales de riesgo	SP 800-55: análisis avanzado; NIST guía de riesgo	Prácticas actuariales; ERM

8.4	Resiliencia y continuidad	NIST CSF: RC; SP 800-55: medidas de impacto	ENS: continuidad de servicios; NIS2: continuidad del negocio
8.5	Índice Global de Madurez (IGM)	SP 800-55: programas de medición agregada	Modelos de madurez
9.1	Presupuesto específico de ciberseguridad	SP 800-55: recursos para el programa	Gobierno corporativo; planificación financiera
9.2	% presupuesto TI en ciberseguridad	SP 800-55: métricas de esfuerzo y coste	Benchmarks sectoriales
9.3	TCO de proyectos de ciberseguridad	SP 800-55: eficiencia y coste	Buenas prácticas de gestión de inversiones
9.4	Cálculo de ROI	SP 800-55: valoración de eficacia y eficiencia	Modelos de gestión financiera
9.5	Priorización basada en riesgo y coste	SP 800-55: uso de métricas en priorización	Gestión de riesgos; NIS2: medidas basadas en riesgo
10.1	Marcos de referencia aplicados	NIST CSF, SP 800-53, ISO 27001	Alineamiento con estándares
10.2	Alineamiento con NIST SP 800-55	SP 800-55 Vol. 1 y 2	Mejores prácticas de medición
10.3	Aplicación del ENS	ENS	ENS: ámbito de aplicación
10.4	Métricas específicas ENS	ENS: evaluación del cumplimiento	ENS: informe de estado y auditoría
10.5	Adaptación a NIS2 y CNCS	SP 800-55: programas a nivel organización/país	NIS2 y futura ley española de ciberseguridad